01. Паспорт технического задания

Платформа управления документами / Modern Tech

Версия 1.0 от 31 октября 2026 года. Назначение: учебный и портфолио-продукт, демонстрирующий полный цикл разработки внутренней системы одной компании. Владелец согласовал функциональный набор и поручил самостоятельно принять остальные проектные решения. Это спецификация будущей реализации, а не отчёт о готовой системе.

Цель. Сотрудник загружает документ, система безопасно извлекает текст, распознаёт сканы и сущности, после чего документ находится по содержимому с учётом прав. Версии, обсуждение и аудит позволяют восстановить контекст изменений. Пользователь может импортировать и экспортировать документы через Яндекс Диск и Облако Mail.

Обязательные результаты. React/TypeScript-клиент, Laravel API, модульная архитектура, очередь обработки, PostgreSQL-поиск, локальное хранение, пять интеграций, Docker Compose, unit/integration/API/E2E-проверки, CI/CD, документация и review через PR. ТЗ поставляется в Markdown и PDF объёмом 28 страниц. Backlog находится в tasks.json и связан с идентификаторами требований.

Среда. Основная демонстрация локальная, Apple M4 Pro, ARM64. Объём RAM пользователь не указал; предварительный бюджет Docker - 12 ГиБ RAM и 40 ГиБ свободного диска, подлежит измерению. Установка требует интернета для образов, моделей и антивирусных баз. После подготовки ядро работает без исходящего интернета. Облачные коннекторы требуют сети и личных аккаунтов, но не блокируют локальные функции.

Статус решений. Продуктовые решения согласованы ответами владельца. Детали в этом документе приняты как инженерная baseline в рамках предоставленного усмотрения. Нагрузочные цели, совместимость ARM64 и реальные API проверяются в ранних задачах. Ни один показатель производительности не объявляется достигнутым до измерения.

Приёмка. Реализация принимается по требованиям FR/NFR, тестам и доказательствам в отчёте. Факт наличия Dockerfile, workflow или mock-теста не доказывает успешный запуск, деплой или реальную интеграцию. Дедлайн не задан; план составляется по зависимостям без вымышленных календарных обещаний.

02. Границы продукта и термины

Документ - логическая запись с названием, владельцем, тегами, папкой и ACL. **Версия** - неизменяемый оригинал файла с контрольной суммой. **Производный артефакт** - извлечённый текст, preview или результат NER. **Публикация** - атомарный выбор версии для поиска по умолчанию. **ACL** - разрешения пользователя на документ. **Передача** - отдельная операция импорта/экспорта.

В первую версию входят загрузки, папки, теги, избранное, полнотекстовый поиск, preview, сущности, версии, комментарии, корзина, администрирование и облачные передачи. Любая тематика документов допускается в пределах поддерживаемых форматов. Поддержка формата не означает понимание любой таблицы, формулы или рукописи.

Не входят: multi-tenant SaaS, биллинг, публичная регистрация, публичные ссылки, наследование ACL от папки, группы/отделы, совместное редактирование Office, электронная подпись, чат с документами, векторный поиск, автоматическая облачная синхронизация, аудио/видео и произвольные архивы. Эти возможности добавляются только через изменение scope.

FR-001. Локальная независимость. После первоначальной подготовки приложение позволяет войти, загрузить файл, обработать его, найти, просмотреть, прокомментировать и создать версию без облачных credentials. Отсутствие интернета отображается только в затронутых интеграциях. Проверка T-001 отключает исходящий интернет и проходит сквозной сценарий, оставляя локальные межконтейнерные соединения.

FR-002. Универсальный архив. Все поддерживаемые документы имеют общую карточку и жизненный цикл. Неопределённый тип тематики не считается ошибкой. Неуспешное распознавание не превращает документ в ложный успешный результат: сохраняются оригинал, статус этапа и причина. Для неподдерживаемого формата загрузка отклоняется до постановки в OCR.

Метрика ценности: доля контрольных поисковых запросов, где нужный доступный документ есть в первых пяти результатах. Дополнительные метрики: время от загрузки до доступности поиска, доля успешно обработанных версий и число ошибок доступа. Реальные интервью не проводились; коммерческий спрос не заявляется доказанным.

03. Пользователи и сценарии

Три роли: администратор, сотрудник и наблюдатель. Администратор автоматически имеет полный доступ ко всем документам и управляет системой. Сотрудник создаёт документы и действует в рамках ACL. Наблюдатель только читает разрешённое содержимое. Системный обработчик выполняет задания от имени инициатора и не является пользовательской ролью.

UC-01. Найти скан. Сотрудник загружает PDF, видит очередь и этап OCR, затем вводит фразу из содержимого. Получает документ с совпавшим фрагментом, открывает preview. При плохом качестве OCR видит предупреждение, а не обещание точного распознавания. Измерение: T-001/T-007 и NFR-002.

UC-02. Обновить инструкцию. Пользователь с edit добавляет версию. Предыдущая опубликованная остаётся доступной до готовности новой. После обработки новая становится текущей; обсуждение старой сохраняет привязку. Конкурирующая загрузка не позволяет запоздалому заданию заменить более свежую версию.

UC-03. Ограничить доступ. Владелец выдаёт коллеге read и comment. Коллега обсуждает файл, но не экспортирует. После отзыва read следующий запрос не возвращает содержимое, фрагменты, счётчики или историю. Администратор продолжает иметь доступ по согласованному исключению.

UC-04. Перенести файл из облака. Сотрудник подключает свой аккаунт, выбирает файл и запускает импорт. Создаётся приватная локальная копия. Она проходит тот же карантин, что локальная загрузка. Удаление оригинала в облаке не удаляет копию автоматически.

UC-05. Выгрузить версию. Пользователь с export выбирает версию и папку своего облака. Система фиксирует назначение, выполняет передачу и показывает подтверждённый результат либо неопределённый исход. Новая локальная версия, появившаяся позднее, не меняет содержимое задания.

UC-06. Разобрать сбой. Администратор видит этап и код ошибки, correlation ID и число попыток, повторяет допустимый этап. Оригинал не перезаписывается, дубли сущностей не возникают. Все административные изменения фиксируются в аудите.

04. Роли, ACL и приватность

FR-003. Вычисление доступа. Для активного администратора разрешены все документные действия. Для остальных: active_user AND role_allows(action) AND document_acl_allows(action) AND resource_state_allows(action). Для владельца сотрудника права полные. Заблокированный пользователь запрещён независимо от роли. Deny-by-default применяется на сервере.

FR-004. Разрешения. read открывает карточку, текст, preview, версии и комментарии. comment разрешает добавлять обсуждение. edit разрешает менять метаданные, корректировать сущности и добавлять версии. export разрешает скачивание оригинала и передачу в облако. comment/edit/export требуют read. API отклоняет неконсистентный набор; UI добавляет read автоматически. Отзыв read снимает остальные разрешения.

FR-005. Управление ACL. Только владелец и администратор выдают права конкретным пользователям. edit не даёт управления ACL или удаления. Наблюдателю нельзя выдать эффективные comment/edit/export. Новые загрузки и импорты доступны владельцу и администраторам. UI использует именно такую формулировку вместо обещания абсолютной приватности.

ACL действует на все версии документа. Папки и теги не выдают доступ к содержимому. Название чужой папки или тег не раскрываются через недоступный документ. Чтение ACL доступно владельцу/администратору; обычный читатель видит свои возможности, но не список чужих доступов.

FR-006. Отзыв и блокировка. Изменение ACL действует на последующие серверные запросы без ожидания переиндексации. Перед выдачей байтов и выполнением queued export проверяются актуальные права. При блокировке инвалидируются сессии. Уже переданные байты, скриншоты и облачные копии не могут быть отозваны; приложение не заявляет DRM-гарантии.

Приёмка T-002. Матрица позитивных и негативных запросов для трёх ролей, владельца и постороннего: list/search/count/preview/download/version/comment/export/ACL. Проверяются подмена идентификаторов, снижение роли владельца и административное исключение. Ни endpoint, ни кэш, ни worker не обходят общую политику.

05. Учётные записи и сессии

FR-007. Управление пользователями. Администратор создаёт пользователя с именем, уникальным email и ролью, блокирует и меняет роль. Публичной регистрации нет. Нельзя заблокировать, удалить или понизить последнего активного администратора. Учётная запись с историей действий деактивируется, а не физически удаляется с каскадным уничтожением аудита.

FR-008. Вход. Laravel Sanctum использует серверную cookie-session для собственной SPA. Один origin обеспечивается reverse proxy. Пароли хешируются штатным механизмом Laravel; сессия регенерируется после входа. Cookies HttpOnly, SameSite=Lax; Secure обязателен в HTTPS-окружении, локальная HTTP-конфигурация явно отдельная. CSRF защищает изменяющие запросы.

FR-009. Приглашение и восстановление. Одноразовые токены хранятся в виде хеша, срок жизни приглашения 24 часа, восстановления 60 минут. Повторное использование запрещено. Ответ восстановления не раскрывает существование email. В локальной поставке письма доступны через Mailpit; это не доставка в настоящий почтовый ящик. Ссылка ведёт на настроенный origin, а не на произвольный Host header.

FR-010. Ограничения входа. Начальная политика: 5 неудачных попыток за минуту по комбинации IP и нормализованного email, далее 429 с Retry-After. Восстановление: 3 запроса за 15 минут. Пароль минимум 12 символов; разрешены длинные passphrase до 128 символов, без искусственного требования спецсимвола. Сообщения об ошибках не выводят внутренние исключения.

FR-011. Выход. Завершение сессии на сервере и очистка Query/Zustand-кэша клиента. Вкладка после 401 возвращает на вход, не продолжает показывать загруженные чувствительные данные. Пользователь может завершить остальные сессии. Смена пароля отзывает остальные сессии.

Приёмка T-003: успешный вход, неверный пароль, CSRF failure, повтор токена, истечение, блокировка активной сессии, ограничение последнего администратора, очищенный клиентский кэш. Демо-пользователи создаются отдельной seed-командой с явно локальными credentials, никогда автоматически в production-профиле.

06. Загрузка и поддерживаемые форматы

FR-012. Входные данные. Разрешены PDF, DOCX, XLSX, PPTX, TXT, MD, CSV, PNG, JPEG. Максимум файла 50 МиБ (52 428 800 байт), пакет до 20 файлов; каждый имеет отдельный результат. PDF/OCR и производный PDF ограничены 200 страницами. Изображение - до 40 мегапикселей. ZIP, исполняемые файлы, аудио/видео и macro-enabled Office отклоняются.

FR-013. Проверка. Проверять расширение, MIME по содержимому и структуру контейнера; заголовок браузера не считается достоверным. Для DOCX/XLSX/PPTX ограничить суммарный распакованный объём 250 МиБ и 10 000 entries. Для текста требуется UTF-8 либо явно распознанная безопасная перекодировка; ошибка кодировки объясняется пользователю. Зашифрованные/защищённые паролем документы первой версией не поддерживаются.

FR-014. Сохранение. Поток поступает во временный приватный объект; вычисляется SHA-256. После проверки размера создаются document/version/outbox в транзакции. Сбой транзакции оставляет объект для последующей уборки. Имя пользователя хранится как метаданные, storage key генерируется сервером. Путь не строится из пользовательского имени. Контрольная сумма не раскрывает наличие чужого документа.

FR-015. UI. Drag-and-drop и выбор файлов, прогресс передачи байтов отдельно от обработки. После принятия API отвечает 202 с version_id и processing status. Отмена до завершения удаляет временный объект; после постановки используется cancel action. Ошибка одного файла не откатывает весь пакет. Повтор сетевого запроса с Idempotency-Key не создаёт новую версию.

Приёмка T-004: нулевой файл, ровно лимит и лимит+1, неправильное расширение, повреждённый Office, path traversal, архивная бомба, защищённый PDF, 201 страница, пакет с частичным успехом, сетевой повтор. Число страниц проверяется до дорогого OCR; файлы, лимит которых нельзя безопасно определить, не запускаются бесконтрольно.

07. Библиотека, папки и теги

FR-016. Библиотека. Строка документа содержит название, формат, владельца, текущую версию, дату изменения и статус. Сортировки: обновление, создание, название; поиск добавляет relevance. Pagination по 25 записей, максимум 100; стабильный tie-break по id. URL сохраняет фильтры и сортировку, позволяя возвращаться к списку.

FR-017. Папки. Каждый пользователь имеет личное дерево папок, глубина до 5, имя до 120 символов. Документ относится максимум к одной папке владельца. Доступный чужой документ показывается в разделе «Доступные мне» без раскрытия закрытой структуры владельца. Администратор может просматривать структуру всех владельцев. Папка не наследует ACL.

Удаление непустой папки запрещено с предложением сначала переместить документы или удалить дочерние папки. Перемещение документа не меняет ACL. Циклическая вложенность запрещена. Точный порядок siblings - название, затем id. Это предотвращает неопределённое поведение дерева при одинаковых названиях.

FR-018. Теги. Сотрудники могут выбирать существующие теги и создавать новые нормализованные названия до 40 символов. На документ до 20 тегов. Администратор объединяет/удаляет теги. Подсказки и счётчики ограничены доступными документами, кроме административного справочника. Удаление тега не удаляет документы.

FR-019. Избранное. Личная связь user-document, уникальная пара. Не выдаёт права и исчезает из выдачи после отзыва read или удаления документа. Пользователь может снять отметку после восстановления доступа. Избранное не входит в экспортируемый файл.

Приёмка T-005: пагинация без дублей при неизменном наборе, фильтры в URL, циклы папок, приватность чужих папок, объединение тегов, доступ к избранному после отзыва. Пустая библиотека предлагает загрузку сотруднику, а наблюдателю объясняет отсутствие предоставленных документов.

08. Версии и публикация

FR-020. Неизменяемость. Версия содержит номер, storage key, SHA-256, размер, detected MIME, оригинальное имя, автора и время. Уникальность (document_id, version_number) обеспечивается БД. Оригинальные байты после создания не изменяются; исправление означает новую версию.

FR-021. Текущая версия. Документ имеет desired_version_id и published_version_id. Новая загрузка атомарно становится desired. Worker публикует готовую версию только если она всё ещё desired и документ не в корзине. Поздний результат старой версии сохраняется в истории, но не вытесняет более новую. При ошибке desired прежняя published остаётся в поиске с предупреждением о неуспешном обновлении.

FR-022. Конкуренция. Метаданные и смена desired используют optimistic lock revision. Клиент передаёт ожидаемую revision; конфликт возвращает 409 и актуальную revision. Нумерация версий выделяется транзакционно. Двойной запрос с одним ключом идемпотентности не расходует два номера.

FR-023. Восстановление. Пользователь с edit выбирает старую clean-версию; создаётся новая запись с новым номером и происхождением restored_from_version_id. Разрешается переиспользовать неизменяемый blob с учётом ссылок; удаление одного указателя не удаляет общий объект. Производные результаты повторно проверяются по версии процессора либо пересоздаются.

FR-024. История. Пользователь с read видит автора, дату, статус, размер и источник версии. Скачать оригинал можно только с export. Комментарий сохраняет исходную version_id, даже если текущая версия изменилась. Сравнение файлов построчно и diff офисных документов не входят в scope.

Приёмка T-006: параллельные загрузки, старое задание завершилось позже нового, failed desired, восстановление старой версии, повтор запроса, конфликт revision и удаление документа во время публикации. Поиск по умолчанию возвращает один документ с published-версией, не смешивая фрагменты разных версий.

09. Конвейер, очередь и повторные попытки

FR-025. Этапы. Uploaded → quarantined → scanning → extracting → recognizing (если нужен OCR) → indexing → ready. Preview и NER имеют самостоятельные статусы pending/running/succeeded/failed/skipped. Ready означает готовый поисковый текст и clean-оригинал; ошибка NER/preview отображается отдельно и не скрывает уже доступный текст.

FR-026. Доставка. Transactional outbox сохраняется вместе с изменением БД. Dispatcher отправляет события в Redis и помечает доставку; возможна повторная отправка. Уникальность результата обеспечивается ключом (version_id, stage, processor_version), а не обещанием exactly-once от брокера. Outbox периодически перечитывается после сбоев.

FR-027. Повторы. Начальный backoff 10/60/300 секунд, максимум 3 попытки для временных ошибок. Постоянная ошибка формата не повторяется автоматически. Таймауты: антивирус 120 секунд, извлечение/preview 180, OCR до 900, NER 180; retry_after превышает timeout соответствующего worker минимум на 60 секунд. Пределы уточняются замерами, не снимаются без ограничения.

FR-028. Изоляция нагрузки. Очереди short, extract, ocr, transfers. Начальная concurrency тяжёлого OCR - 1, остальных - по 2. Кэш Redis отделён от queue Redis с noeviction и AOF для очереди. PostgreSQL хранит авторитетное состояние; потеря брокера восстанавливается по outbox и reconciliation, а не признанием документов завершёнными.

FR-029. Отмена и retry. Владелец или администратор отменяет обработку, пользователь с edit повторяет failed-этап. Worker проверяет tombstone/cancel и актуальность версии перед публикацией. Reconciler каждые 5 минут находит просроченные lease и возвращает допустимые задания. Временные объекты старше 24 часов убираются только после проверки отсутствия ссылок.

Приёмка T-008: остановка worker между записью результата и ack, повтор outbox, рестарт Redis, poison file, превышение timeout, ручной retry и удаление во время OCR. Ни сценарий не создаёт дубли версии, текста или сущностей.

10. Антивирус, извлечение и preview

FR-030. ClamAV. Приватный clamd получает поток до запуска парсеров. Clean разрешает следующий этап; infected переводит в rejected, timeout/недоступность оставляет карантин. Отсутствие баз никогда не считается clean. Возраст баз виден администратору; обновление через FreshClam отдельно от обработки документов. Заражённый оригинал не доступен для обычного скачивания.

FR-031. Tika/Tesseract. Сначала извлекается встроенный текст. Для image-only или смешанного PDF OCR применяется к страницам без пригодного текста, с моделями rus+eng. На раннем эксперименте проверяется способность выбранного адаптера корректно выделять такие страницы; при необходимости используется ограниченный постраничный orchestration. Нельзя повторно накладывать два одинаковых текста на одну страницу.

FR-032. Gotenberg. DOCX/XLSX/PPTX преобразуются в PDF для просмотра в изолированном сервисе. Шрифты с кириллицей входят в образ. Office-формулы не вычисляются ради извлечения внешних данных; макросы не исполняются. Для таблиц сохраняется доступный текст ячеек, но не обещается идентичная печатная раскладка. Preview PDF ограничивается 200 страницами.

FR-033. Просмотр. PDF отображается безопасным viewer, изображения - как растровые файлы, TXT/MD/CSV - как экранированный текст. Markdown не исполняет HTML. Preview выдаётся через авторизованный backend; постоянных публичных storage URL нет. Исходный файл и preview имеют разные разрешённые MIME и Content-Disposition.

Парсеры работают без привилегий, с лимитами памяти/CPU/времени, без Docker socket и исходящих соединений за пользовательскими URL. Сетевой доступ к источникам разрешён только адаптерам интеграций. Встроенные ссылки и внешние XML entities не загружаются.

Приёмка T-009: EICAR, отсутствие баз, смешанный PDF, кириллица, повреждённый DOCX, внешний URL в документе, отказ Gotenberg, запрос preview после отзыва ACL. Качество conversion и ARM64-совместимость подтверждаются на фиксированном наборе файлов.

11. Извлечение сущностей

FR-034. Локальная NER. Отдельный локальный Python-процесс с моделями spaCy RU/EN выделяет людей, организации и места. Даты, email и телефоны извлекаются детерминированными правилами. Модель и её версия сохраняются вместе с результатом. Облачный LLM не требуется и документы ему не отправляются.

FR-035. Представление. Сущность содержит type, raw_value, normalized_value, source_segment, start/end offset, extractor_version и review_status. Смещения определяются в Unicode code points исходного сегмента, не в байтах UTF-8 и не в токенах. Клиент получает отдельный текстовый контекст; преобразование offset в JS учитывает различие code points/UTF-16.

FR-036. Проверка человеком. Пользователь с edit подтверждает, отклоняет или исправляет значение. Хранятся исходное машинное предложение и исправление с автором/временем. Повторный NER той же версии не уничтожает человеческие решения. Новая версия имеет собственный набор сущностей; автоматический перенос подтверждения на изменённый текст запрещён.

FR-037. Неопределённость. Не показывать выдуманный confidence, если модель не даёт калиброванной вероятности. Дата «03/04» без достаточного контекста остаётся исходной строкой, а не уверенно превращается в конкретную дату. Телефон нормализуется только при определимом формате. Ненайденные сущности не означают ошибку документа.

NER может завершиться позже индексации. Пользователь видит «Сущности обрабатываются» или причину сбоя и retry для уполномоченного пользователя. Запросы сущностей проходят те же ACL, что содержимое. Фильтры по сущностям учитывают только актуальную опубликованную версию.

Приёмка T-010: смешанные языки, омонимы, даты с неоднозначным форматом, emoji рядом со span, повтор задания после ручной корректировки, смена версии и отказ модели. Контрольный корпус содержит разметку; precision/recall измеряются отдельно по типам. Цели качества определены в разделе 24 и не считаются уже достигнутыми.

12. Полнотекстовый поиск и ранжирование

FR-038. Индекс. PostgreSQL FTS индексирует текст сегментами до 16 000 символов с перекрытием до 200 символов. Заголовок и текст имеют отдельные веса. RU/EN конфигурации выбираются по сегменту; для идентификаторов используется нормализованный точный поиск. GIN поддерживает tsvector; ограничения размера проверяются до записи.

FR-039. Запрос. Поле до 500 символов, обычные слова и фраза в кавычках; SQL строится параметризованно. Глобальный wildcard/произвольный SQL/регулярное выражение не принимаются. Пустой запрос возвращает библиотеку с фильтрами. Фраза длиннее перекрытия сегментов может не находиться через границу; это документированное ограничение, а не скрытая потеря результата.

FR-040. Ранжирование. Начальный score: совпадение названия вес 4, подтверждённых сущностей/тегов 2, текста 1; внутри текста используется ts_rank_cd. Совпадения сегментов агрегируются по документу через максимальный score с ограниченной добавкой за дополнительные сегменты, чтобы длинный файл не выигрывал только объёмом. После relevance применяется updated_at и id как стабильный tie-break. Веса уточняются контрольным корпусом через ADR.

FR-041. Выдача. Один результат на документ, только published-версия. До 2 фрагментов по 240 символов. Все фрагменты экранируются; подсветка создаётся из безопасных текстовых диапазонов, не доверенного HTML. Пользователь может открыть страницу PDF, если координаты страницы известны; для Office показывается текстовый контекст без ложной точной страницы.

FR-042. Безопасность. ACL, active_user и отсутствие deleted_at применяются в запросе до count, сортировки и pagination. Недоступные документы не влияют на показанные total, подсказки и facets. Общий кэш результатов между пользователями не вводится. Изменение ACL не требует фоновой синхронизации отдельного поискового движка.

Приёмка T-007: RU-словоформы, EN, точный номер, фраза, OCR-ошибка, длинный документ, фильтры, одинаковый score и запрет утечек. Для исторических версий доступен просмотр текста, но общий поиск по всем версиям не входит в baseline.

13. Комментарии и совместная работа

FR-043. Комментарии. Комментарий относится к document_id и version_id, содержит plain text длиной 1-5000 символов и автора. Ответы имеют parent_id, максимальная глубина обсуждения - один уровень; UI показывает плоскую ветку. Ссылка на другую версию того же документа допустима, подмена document/version пары отклоняется.

FR-044. Изменение. Автор с действующими read+comment редактирует и удаляет собственный комментарий; администратор может скрыть любой. Пользователь с edit документа не получает право менять чужой текст. Удаление оставляет tombstone «Комментарий удалён», чтобы ответы не теряли контекст. В аудите хранится факт и revision, а не полный текст по умолчанию.

FR-045. Состояния. История изменений документа не меняет привязку комментария. При выборе версии фильтр показывает её обсуждение; дополнительный переключатель показывает все версии доступного документа. После отзыва read не возвращаются ни комментарии, ни их счётчики. Корзина переводит обсуждение в режим чтения для владельца и администратора.

FR-046. Согласованность клиента. Создание и редактирование инвалидируют соответствующий Query cache. Optimistic UI допускается только с откатом при 403/409/422. Двойное нажатие не создаёт два комментария: mutation блокирует повтор, сервер поддерживает Idempotency-Key. После конфликта редактирования пользователь видит актуальный текст и свой несохранённый ввод.

Realtime-сокеты, упоминания, прикрепление дополнительных файлов к комментарию и аннотации поверх PDF не входят в первую версию. Для актуализации достаточно refetch при фокусе и ручного обновления; состояния обработки опрашиваются отдельно с backoff.

Приёмка T-011: комментарий, ответ, собственное редактирование, попытка правки чужого, XSS-строка, превышение длины, двойной запрос, потеря ACL во время редактирования, удалённый parent. Все ошибки доступны с клавиатуры и не уничтожают введённый текст без сообщения.

14. Корзина, хранение и аудит

FR-047. Корзина. Владелец и администратор выполняют soft delete с датой purge_after = deleted_at + 30 дней. Документ немедленно исчезает из обычного поиска и очередей передачи. Просмотр корзины только владельцу/администратору. Восстановление возвращает прежнюю ACL и published-версию, если артефакты сохранны; UI показывает восстановленные права.

FR-048. Очистка. Администратор может удалить окончательно раньше срока. Scheduler удаляет просроченные документы, производные артефакты и blobs без живых ссылок. Операция идемпотентна: частичный сбой оставляет purge job для повтора. Запоздалые workers проверяют tombstone и не создают документ заново. Отсутствие файла в storage фиксируется как диагностика, не как успешная выдача пустого файла.

FR-049. Аудит. События: login outcome, user/role changes, ACL changes, upload/version/publish/restore/delete, comment mutations, entity review, import/export start/result и административный retry. Поля: event_id, actor_id/системный актор, action, resource_type/id, version_id, outcome, request_id/job_id, timestamp UTC, минимальные безопасные metadata.

Успешное изменение ACL/версии и соответствующий audit event записываются в одной транзакции. Ошибка аудита блокирует такое изменение. Диагностические логи не заменяют аудит. Хеширование/подпись цепочки не заявлены; администратор БД технически может изменить таблицу, поэтому криптографической неизменяемости нет.

FR-050. Доступ к аудиту. Глобальный журнал только администратору, фильтры по актору, типу, времени и outcome; содержимое документов и credentials не журналируются. Пользователь видит историю своего документа через отдельные доменные события, не произвольный глобальный лог. Срок аудита baseline 365 дней; удаление содержимого не стирает минимальный факт операции.

Приёмка T-012: restore, purge по сроку, повтор purge, общий blob, worker после удаления, audit rollback и фильтрация журнала. Backup имеет отдельный срок хранения: физическое удаление из активного storage не означает мгновенного удаления всех резервных копий.

15. Яндекс Диск: подключение и импорт

FR-051. Подключение. Личный connection принадлежит пользователю. Официальный REST API и OAuth используются с минимально необходимыми разрешениями чтения/записи. Сервер проверяет state и поддерживаемый flow; токен не сохраняется в браузере. Локальный redirect URI, регистрация приложения и точные scopes проверяются ранним compatibility spike. Неподдерживаемый OAuth-flow нельзя заменить незаметно вводом основного пароля.

FR-052. Листинг. Пользователь видит файлы своего подключённого диска постранично, выбирает папку и до 20 файлов. В интерфейсе отдельно обозначены неподдерживаемые форматы. Просмотр чужого connection_id запрещён даже администратору; административный доступ к локальным документам не даёт облачные credentials.

FR-053. Импорт. Создаётся transfer с инициатором, remote identifier/path и доступным маркером версии. Download идёт серверным потоком с фактическим лимитом размера, затем общий upload pipeline. Результат - новый приватный локальный документ. Имя источника и время импорта видны в карточке; изменение источника не обновляет копию автоматически.

Повтор одного transfer не создаёт дубль. Повторный осознанный импорт того же файла показывает выбор: создать отдельный документ или новую версию ранее импортированного документа при наличии edit. Совпадение checksum чужого файла не раскрывается. Изменение удалённого файла во время скачивания обнаруживается доступными metadata/хешем; при невозможности гарантии фиксируется snapshot полученных байтов.

FR-054. Ошибки. 401/403 требуют переподключения, rate limit даёт backoff, удалённый ресурс - понятную постоянную ошибку. Redirect/download адреса валидируются по разрешённой политике провайдера; авторизация не пересылается неизвестному хосту. Операции не загружают локальный документ в облако без явного export.

Приёмка T-013: OAuth state mismatch, чужой connection, листинг, кириллица, unsupported file, лимит потока, retry и реальный импорт безопасного тестового файла. Mock-тесты обязательны в CI, live smoke отдельно подтверждает работу с настоящим аккаунтом; его отсутствие означает непроверенную интеграцию.

16. Облако Mail: подключение и импорт

FR-055. Подключение. Используется официально описанный WebDAV endpoint https://webdav.cloud.mail.ru и пароль внешнего приложения. Основной пароль аккаунта не запрашивается. Под «Mail диском» понимается пользовательское Облако Mail, не VK Cloud Object Storage. Недокументированный внутренний API сайта не используется.

Connection хранит provider, owner_id, display_name, encrypted credential, status и last_checked_at. Секрет после сохранения не возвращается UI. Ключ шифрования хранится отдельно от БД и образа, входит в процедуру безопасного восстановления. Disconnect удаляет локальный секрет и запрещает новые задания; инструкция объясняет отдельный отзыв пароля на стороне Mail.

FR-056. WebDAV-листинг. PROPFIND Depth:1 с ограничением объёма ответа, безопасным XML parser без внешних сущностей и нормализацией пути. Имена с пробелами, кириллицей, percent-encoding и зарезервированными символами не дают path traversal. Бесконечный рекурсивный обход не применяется. Поддержка pagination/ETag зависит от реального провайдера и проверяется отдельно.

FR-057. Скачивание. Потоковый GET в локальный карантин, тот же лимит и контроль формата, что локальная загрузка. Размер из metadata не считается единственной защитой. Облачные permissions не переносятся на локальный документ. Недоступный WebDAV не ломает локальные функции и не отображается как общая неисправность приложения.

Состояния подключения: unconfigured, checking, connected, authorization_required, temporarily_unavailable, disconnected. Проверка соединения выполняет минимальный безопасный запрос, не сканирует всё облако и не скачивает пользовательские файлы автоматически.

Приёмка T-014: неверный app password, TLS failure, XML с внешней сущностью, многозначный HTTP status, кириллический путь, oversized response, прерывание потока и реальный импорт. Бесплатность доступа на конкретном аккаунте и ограничения WebDAV проверяются live; платная подписка не становится скрытой обязательной зависимостью. При несовместимости фиксируется блокер, а не подмена провайдера.

17. Экспорт в оба облака

FR-058. Инициирование. Пользователь с read+export выбирает документ, конкретную clean-версию, своё подключение и папку. По умолчанию - опубликованная версия и оригинальные байты. Комментарии, ACL, аудит, извлечённые сущности и PDF-preview в файл автоматически не добавляются. Для пакета создаётся отдельный transfer на каждый файл.

FR-059. Стабильность. version_id, blob checksum и planned_remote_path фиксируются при создании задания. Новые версии документа не меняют transfer. Worker повторно проверяет активность пользователя, права, состояние документа и подключение перед передачей. Результат хранит remote identifier, размер и подтверждение провайдера, если доступны.

FR-060. Имена. По умолчанию формируется имя с коротким transfer ID; молчаливая перезапись запрещена. У Яндекса используется возможность запрета overwrite после проверки контракта. Для WebDAV проверяется conditional create; один предварительный листинг не гарантирует отсутствие гонки. Если безопасный режим не подтверждён, передача остаётся заблокированной до решения, а не пишет поверх существующего файла.

FR-061. Неопределённый исход. queued/running/succeeded/failed/cancelled/outcome_unknown. Если связь оборвалась после возможной записи, сначала сверяется назначение и содержимое доступными средствами. ETag не считается автоматически checksum. При отсутствии достоверной сверки UI показывает неопределённость и предлагает проверить файл, вместо бесконтрольного повтора и дублей.

FR-062. Видимость. Экспортированная копия подчиняется правам облачной папки. UI сообщает, что локальный отзыв ACL не удалит её. Публичная ссылка не создаётся. Отмена работающей передачи - best effort: уже отправленные байты нельзя гарантированно отозвать. Приложение не удаляет удалённые файлы автоматически.

Приёмка T-015: оба провайдера, конфликт имени, недостаток квоты, forbidden, повтор job, сетевой разрыв до/после записи, новая локальная версия и отзыв ACL перед запуском. Live round-trip сравнивает SHA-256 экспортированного и скачанного обратно безопасного тестового файла.

18. Пользовательский интерфейс и доступность

FR-063. Навигация. Основные разделы: библиотека, избранное, доступные мне, передачи, корзина; администратору дополнительно пользователи, обработка и аудит. Поиск расположен в библиотеке и сохраняет состояние в URL. Карточка документа содержит preview, метаданные, сущности, версии, комментарии и управление доступом при соответствующих правах.

FR-064. Визуальный язык. Светлая и тёмная темы; нейтральные поверхности, графитовый текст и один синий акцент. shadcn/ui используется как база, не как готовый продуктовый дизайн. Типографика и отступы единообразны. Главные действия имеют текстовые названия, опасные - ясное описание результата. Нет декоративных графиков без полезных данных.

FR-065. Состояния. Для каждого экрана предусмотрены loading, empty, error, denied и offline. Для документа отдельно: карантин, обработка, готов с предупреждением, ошибка и корзина. Прогресс передачи байтов не смешивается с OCR; точный процент обработки не выдумывается. Ошибка указывает действие: повторить, переподключить, выбрать другой файл или обратиться к администратору.

FR-066. Адаптация. Desktop 1280-1920 px основной сценарий; при 360 px доступны поиск, загрузка, карточка и комментарии. Таблица превращается в компактные строки, действия доступны без горизонтального поиска. Большие документы могут просматриваться с прокруткой внутри viewer. Не требуется мобильная идентичность всех административных таблиц.

NFR-001. Доступность. Ориентир WCAG 2.2 AA для собственного UI: клавиатурная навигация, видимый фокус, labels, объявление ошибок, контраст текста минимум 4.5:1 и крупных элементов 3:1, уменьшение анимации. Цвет не единственный индикатор. Доступность содержимого произвольного загруженного PDF не гарантируется интерфейсом.

Приёмка T-016: ручное прохождение клавиатурой, автоматическая accessibility-проверка ключевых экранов, оба theme, 360/1280 px, длинное имя файла, пустая выдача и 403 во время действия. Финальные скриншоты входят в отчёт релиза.

19. Архитектура и стек

Модульный монолит. Laravel API объединяет Identity, Access, Documents, Processing, Search, Entities, Collaboration, Audit и Integrations. Модули владеют бизнес-правилами и таблицами; взаимодействуют через явные сервисы/события. Общая БД позволяет транзакционно менять ACL, метаданные и audit. Отдельные workers масштабируют тяжёлые этапы без распределения всей доменной логики по микросервисам.

Клиент. React, TypeScript strict, Vite, Zustand, TanStack Query, shadcn/ui. Структура FSD pages-first: app/pages/features/shared. Код страницы остаётся в её слайсе до реального повторного использования. Features содержат повторяемые пользовательские действия, shared - инфраструктуру и UI-примитивы. Импорты только вниз по слоям, public API слайсов, без прямых cross-page импортов.

Сервер. Baseline Laravel 13 и PHP 8.4; совместимость Scramble/Sanctum и точные версии подтверждаются setup-задачей и lockfiles. PostgreSQL 18 для метаданных и FTS, Redis для очереди и отдельно кэша. Файлы в закрытом volume через Storage adapter. Python NLP-сервис не получает публичный порт. Внутренние API имеют сетевые ограничения и ограниченный размер payload.

Контракт. Scramble экспортирует OpenAPI, openapi-typescript генерирует TS; openapi-fetch/openapi-react-query связывают клиент. Согласованный контракт проектируется до реализации endpoint, затем CI проверяет экспорт и отсутствие необъяснимого diff. Нельзя вручную поддерживать расходящиеся TS DTO и серверные схемы.

Границы доверия. Browser → reverse proxy → API; API/worker → DB, storage и обработчики; transfer worker → разрешённые облачные endpoints. Интернет-доступ OCR/preview запрещён. Секреты только серверные. Подробные C4 и sequence diagrams расположены в ARCHITECTURE.md.

Точные версии npm, Python-моделей и образов закрепляются после compatibility spike, включая ARM64 manifest и лицензионный обзор. latest в воспроизводимых окружениях не используется. Неудачная совместимость меняет ADR, а не скрыто удаляет функцию из требований.

20. Модель данных и целостность

Основные идентификаторы UUID, время timestamptz UTC, размеры bigint. users: email unique, role enum, status, password_hash. sessions и password_tokens отделены. documents: owner_id FK, title varchar(255), folder_id nullable, revision bigint, desired_version_id/published_version_id nullable, deleted_at/purge_after. Указатели версии проверяются на принадлежность документу.

versions: document_id, number, blob_id, creator_id, source, restored_from_version_id, state, created_at; unique(document_id,number). blobs: storage_key unique, sha256, size, mime, scan_state. Реализация общего blob допускается только с корректным подсчётом живых ссылок; checksum не становится публичным поиском чужих файлов.

processing_runs: version_id, stage, processor_version, status, attempt, lease_until, error_code; уникальный ключ этапа. text_segments: version_id, ordinal, page nullable, content, language, tsvector; unique(version_id,ordinal), GIN(tsvector). artifacts: version_id, kind, processor_version, storage_key, state. entity_candidates и entity_reviews хранят машинные и человеческие данные раздельно.

document_grants: document_id,user_id,read,comment,edit,export; unique(document_id,user_id). folders: owner_id,parent_id,name. tags: normalized_name unique. document_tags и favorites имеют составные unique. comments: document_id,version_id,author_id,parent_id,body,revision,deleted_at. Проверки parent/document/version выполняются транзакционно.

connections: owner_id,provider,encrypted_secret,status. transfers: direction,initiator_id,connection_id,document_id/version_id nullable,remote_reference,destination,status,idempotency_key,result. outbox: event_id,payload_version,type,payload,dispatched_at. audit_events append-only через приложение. idempotency_records: actor,route,key,request_hash,response,status,expires_at.

Индексы: documents(owner_id,deleted_at), grants(user_id,document_id), transfers(initiator_id,status), runs(status,lease_until), audit(created_at,actor_id), outbox(dispatched_at,created_at). Foreign keys не каскадируют удаление аудита. Миграции обратимы, когда это не уничтожает данные; разрушительные изменения выполняются expand/contract с backup.

Приёмка T-017: ограничения unique/FK, две параллельные версии, неправомерная связь parent, восстановление миграции на тестовой БД и отсутствие N+1 на списке документов. ER-диаграмма и словарь ошибок дополняют схему перед реализацией API.

21. API и контрактные правила

Все доменные маршруты /api/v1. JSON UTF-8, UUID как строки, ISO 8601 UTC, bigint size сериализуется безопасно для клиента. Ответ ресурса {data}; список {data,meta:{page,per_page,total}}. Ошибка {error:{code,message,details,request_id}}; details содержит ошибки полей, но не stack trace. 401 без сессии, 403 на запрещённое действие известного доступного ресурса, 404 для недоступного чужого ресурса, 409 conflict, 422 validation, 429 rate limit, 503 временная зависимость.

Основные маршруты: GET /me; POST /auth/login,/auth/logout,/auth/forgot-password,/auth/reset-password; GET/POST /users и PATCH /users/{id}; GET/POST /documents; GET/PATCH/DELETE /documents/{id}; POST /documents/{id}/restore; GET/POST /documents/{id}/versions; POST /versions/{id}/restore; GET /versions/{id}/preview,/download.

Поиск GET /search?q=&page=&format=&tag=&owner=&status=. ACL GET/PUT /documents/{id}/grants. Комментарии GET/POST /documents/{id}/comments, PATCH/DELETE /comments/{id}. Сущности GET /versions/{id}/entities, PATCH /entities/{id}/review. Папки/теги/избранное имеют отдельные CRUD/actions с правилами раздела 7.

Интеграции GET/POST /connections, POST /connections/{id}/check,/disconnect; GET /connections/{id}/files; POST /imports,/exports; GET /transfers; POST /transfers/{id}/cancel,/retry. Управление обработкой POST /versions/{id}/retry,/cancel; GET /admin/jobs,/admin/audit. System endpoints /health/live,/health/ready,/metrics имеют отдельную экспозицию.

Idempotency-Key обязателен для загрузки, создания версии, комментария и transfer. Ключ scoped по actor+route; TTL 24 часа. Тот же key с другим request hash даёт 409. In-progress повтор возвращает существующую операцию; завершённый - исходный результат, если текущие права ещё позволяют его видеть. PATCH использует revision.

Контракт включает multipart-upload, cookies/CSRF, двоичные ответы, все ошибки и примеры. Генерация TS не заменяет runtime validation сервера. Приёмка T-018 проверяет соответствие реальных ответов OpenAPI и backward-incompatible diff. Машиночитаемая полная схема создаётся до клиентских/API задач, отдельной задачей backlog.

22. Безопасность и конфиденциальность

NFR-003. Угрозы. Основные активы: оригиналы, текст, credentials, ACL и audit. Угрозы: посторонний пользователь, злоумышленный файл, захваченная сессия, повтор job, утечка через поиск, внешние редиректы и ошибка администратора. Полный доступ администратора согласован; он не означает доступ к секретам чужих облаков.

Загрузка проходит allowlist, карантин и антивирус до парсинга. Контейнеры обработки non-root, read-only rootfs где возможно, ограниченные tmpfs, CPU/RAM/pids, без привилегий. Archive/XML bombs, decompression limits и timeouts входят в негативные тесты. Сбой антивируса закрывает путь обработки, а не открывает его.

Все SQL параметризованы, HTML/Markdown/подсветка экранированы. API запрещает mass assignment роли/owner_id через пользовательский payload. Права проверяются по связанному ресурсу, а не только endpoint. Серверная SSRF-политика валидирует схему, host, DNS/private IP и каждый redirect; TLS verification не отключается для устранения ошибки интеграции.

Секреты шифруются Laravel encryption; ключи в отдельном окружении, .env не коммитится. Логи редактируют Authorization, cookies, passwords и токены. На demo только синтетические/разрешённые документы. Подключения провайдера требуют явного действия пользователя. Произвольные URL для импорта не поддерживаются.

Образы и зависимости проверяются сканером; критические подтверждённые уязвимости на пути исполнения блокируют выпуск. Каждое исключение имеет обоснование и срок, не подавляется целая категория. Внешние исходники/документы не считаются инструкциями для автоматизированного агента.

Приёмка T-019: CSRF, IDOR, XSS, SSRF redirects, XXE, file bomb, privilege escalation, credentials в логах и поиск после ACL revoke. Результат оформляется threat-model checklist с доказательствами. Это инженерная проверка, не сертификат соответствия законодательству; обработка реальных чувствительных данных требует отдельного контекста.

23. Docker Compose и эксплуатация

FR-067. Состав. reverse-proxy/web, api, worker-short, worker-ocr, worker-transfers, scheduler, postgres, redis-queue, redis-cache, tika, gotenberg, clamav, nlp, mailpit. Prometheus/Grafana включаются профилем monitoring. API и workers используют один образ приложения с разными командами; разнесение процессов не означает отдельные микросервисы бизнес-логики.

FR-068. Запуск. README задаёт установку Docker/Compose, .env.example, build, migrate, bootstrap-admin и start. Скрипт bootstrap генерирует локальные секреты при отсутствии и не перезаписывает существующие. Демо seed запускается явно. Зависимости имеют healthcheck и retries; depends_on service_healthy не заменяет обработку позднего падения сервиса.

Публично на localhost доступны только web, локальная почта и явно выбранный monitoring. БД, Redis и обработчики не публикуются наружу. Persistent volumes: PostgreSQL, originals/artifacts, queue AOF, ClamAV DB. Токены и пользовательские данные не запекаются в image. Сброс volumes требует явной отдельной команды и предупреждения о данных.

NFR-004. ARM64. На M4 Pro проверяется native manifest каждого образа. Эмуляция amd64 допускается только как документированное временное отклонение с измерением времени и памяти. Начальные лимиты тяжёлых обработчиков и concurrency конфигурируются; после benchmark записывается реальный пик RAM. Профиль low-memory уменьшает параллелизм, но не отключает ACL или антивирус.

FR-069. Offline. После подготовки образов, шрифтов, RU/EN моделей и антивирусных баз ядро проходит тест без внешней сети. Проверка свежести баз может показать предупреждение; без самих баз загрузки не признаются безопасными. Облачные передачи переходят в временную ошибку и не блокируют поиск по локальному архиву.

Приёмка T-020: чистый старт, повторный старт без потери данных, reboot workers, недоступность БД после старта, offline core, проверка портов и ARM64. Версии и digest фиксируются в manifest; релиз не зависит от изменчивого latest.

24. Производительность и качество

Все значения ниже - цели приёмки, не результаты. Нагрузочный профиль: Apple M4 Pro, Docker с 12 ГиБ RAM, 10 одновременных пользователей, 10 000 документов, среднее извлечённое содержимое 50 КиБ, 100 контрольных поисковых запросов. Отдельный набор тяжёлых файлов до 50 МиБ/200 страниц проверяет пределы; он не подменяет средний профиль.

NFR-002. Скорость. На прогретом индексе p95 поиска не более 1 секунды при 5 запросах/сек в течение 10 минут. Обычный список/API p95 не более 500 мс, исключая передачу файлов и внешние API. Измерять и server latency, и browser-visible latency. Ноль утечек ACL - безусловный критерий, не статистический процент.

NFR-005. Обработка. Контрольный 20-страничный текстовый PDF доступен поиску не позднее 30 секунд после принятия, 10-страничный печатный скан 300 dpi RU/EN - не позднее 180 секунд без backlog. Отдельно измеряется ожидание очереди и работа обработчика. Максимальный 200-страничный OCR может занимать до stage timeout; превышение показывает failed/timeout, не вечное running.

NFR-006. Качество. Корпус: минимум 60 разрешённых файлов, не менее 5 каждого формата, включая смешанные PDF и ошибки. Для 50 размеченных запросов Recall@5 не ниже 0.90. Для чистых печатных сканов CER не выше 0.10 на размеченной выборке; рукописи исключены. NER micro precision не ниже 0.80, recall не ниже 0.70 на 200 размеченных сущностях, с отдельным отчётом RU/EN и по типам. Пороги не снижаются молча при неуспехе.

NFR-007. Надёжность. Повтор задания не создаёт дубль; сбой новой версии не скрывает published. На локальном стенде не обещается коммерческий uptime SLA. Отсутствие места на диске приводит к понятному отказу и метрике, не порче опубликованных данных.

Приёмка T-021: воспроизводимый dataset seed, версия корпуса, команды benchmark, hardware/RAM/concurrency, warm/cold результаты и percentile distribution. Если реальные ресурсы отличаются, профиль и результаты фиксируются до оценки соответствия.

25. Наблюдаемость, backup и восстановление

FR-070. Логи и метрики. JSON logs: timestamp, severity, service, request_id/job_id, error_code, duration; без текста документов и credentials. Метрики: HTTP latency/errors, queue depth/oldest age, stage duration/failure, transfers outcome, storage free, DB connectivity и outbox lag. user_id/document_id не используются как metric labels высокой кардинальности.

FR-071. Health. Liveness показывает работоспособность процесса. Readiness API проверяет БД, storage и необходимые локальные зависимости с bounded timeout; состояние отдельных обработчиков дополнительно показывается как component health. Недоступный облачный провайдер не делает всё приложение unready. /metrics и диагностические подробности доступны только внутренней сети/администратору.

Алерты demo: oldest queue age более 5 минут, outbox lag более 2 минут, диск менее 10% свободен, серия stage failures и отсутствующая база ClamAV. Длительный OCR сам по себе не считается ошибкой HTTP. Администратор видит correlation ID и инструкции runbook, а не stack trace пользователю.

FR-072. Backup. Для локального стенда ежедневный согласованный snapshot БД и файлов, хранение 7 последних копий. На время snapshot приостанавливаются новые записи/purge либо используется проверенный согласованный snapshot-процесс. Ключ шифрования connections резервируется отдельно; без него восстановленные credentials непригодны. Backup на том же диске не защищает от физической потери устройства, что явно указано в README.

NFR-008. Восстановление. Цель RPO 24 часа при выполняющемся расписании и RTO 60 минут для контрольного архива до 5 ГиБ. На выключенном ноутбуке scheduler не обещает ежедневный backup. Restore в чистые volumes проверяет количество записей, SHA-256 выборки оригиналов, ACL и поиск. FTS/preview допускается перестроить из originals, но это учитывается в RTO.

Приёмка T-022: повреждённый backup, отсутствующий encryption key, восстановление чистого стенда, outbox reconciliation и отсутствие повторного экспорта после restore. Незавершённые передачи после восстановления требуют сверки удалённого исхода, а не автоматической повторной отправки.

26. Тестирование и критерии готовности

Unit: вычисление ролей/ACL, transition guards, нормализация сущностей, имя экспорта, idempotency. Integration: реальный PostgreSQL/Redis/storage, outbox, параллельные версии, purge, конвейер с контролируемыми зависимостями. API: session/CSRF, schema, upload limits, все отрицательные права. Frontend: поведение форм, ошибок, cache invalidation и смены сессии. E2E: ключевые сценарии в браузере с настоящим API.

В CI короткий набор выполняется на каждом PR. Тяжёлый OCR, нагрузка, restore и live cloud smoke - отдельные явные jobs/manual runs. Пропущенная проверка не обозначается passed. Реальные облачные аккаунты не требуются для обычного PR; fixture-тесты не заменяют финальный live round-trip обоих провайдеров.

Тестовые артефакты синтетические или с разрешённой лицензией. EICAR применяется как безопасный стандартный тест антивируса, не как реальный вредоносный файл. Для OCR и NER сохраняются эталоны, версии моделей и метод расчёта метрик. Преднамеренно ошибочные файлы ограничены по ресурсам тестового окружения.

Definition of Ready. Задача связана с FR/NFR, зависимости завершены, контракт и ошибки определены, критерии доступны для проверки. Если задача требует внешнего аккаунта, эта зависимость обозначена, а не скрыта в конце реализации.

Definition of Done. Все acceptance criteria и test_steps выполнены, evidence записано; lint/typecheck/build проходят, негативные права проверены, документация/миграции обновлены, Для кода после настройки remote PR принят reviewer; исследование и bootstrap до remote подтверждаются локальным отчётом. Локально завершённая кодовая задача после настройки remote без доступного review не выдаётся за прошедшую PR-проверку; статус review_pending отражается в evidence до окончательного done.

Приёмка T-023: отчёт по T-001..T-024, список проваленных/пропущенных тестов, связанные issues и решение о выпуске. Критические потери данных, утечки ACL, ложный success экспорта и невоспроизводимый запуск блокируют релиз. Общий процент покрытия не заменяет проверки опасных сценариев.

27. CI/CD, review и демонстрация

FR-073. CI. GitHub Actions на pull_request: форматирование/линтеры PHP/TS, PHP static analysis, TS strict, unit/integration/API, OpenAPI validation/generation diff, web build, Docker build и vulnerability scan. Действия закреплены по проверенной версии/commit; права workflow минимальные. Fork PR не получает облачные или deploy secrets.

FR-074. PR review. Каждая функциональная порция в отдельной ветке, PR содержит проблему, поведение, связанные требования и результаты проверок. Изменение схемы/ACL требует проверки миграции и негативных тестов. Автоматизированное review дополняет тесты, но не даёт фиктивного человеческого одобрения. Конкретный reviewer ещё не назначен; до первого merge владелец выбирает его или явно фиксирует доступную процедуру review.

FR-075. Локальный deploy. После merge собираются неизменяемые образы с commit SHA. Demo deploy запускается вручную для доверенного commit: backup, pull/load image, migrations, restart workers, readiness и smoke. Для автоматизации возможен выделенный self-hosted runner, который не выполняет недоверенные PR. Если runner отсутствует, release-команда выполняет тот же процесс локально с журналом.

Rollback возвращает предыдущие образы, только если схема совместима; иначе используется проверенное восстановление snapshot. Обновления схемы строятся expand/contract. «Сборка прошла» не равна «деплой выполнен». Приёмка T-024 требует фактического обновления стенда и отката с проверкой данных.

Render - опционально. По официальной документации бесплатные web services имеют ephemeral filesystem, не поддерживают persistent disk, а бесплатная PostgreSQL имеет ограниченный срок жизни. Поэтому полный Compose с локальными файлами и постоянными workers не объявляется бесплатным эквивалентом локального стенда. Перенос потребует отдельного deployment ADR и оценки ресурсов; в обязательную приёмку входит локальная демонстрация.

При отсутствии GitHub remote/credentials готовятся workflow и локальные проверки, но реальный PR, публикация образов и GitHub-run отмечаются невыполненными до подключения. Удалённый деплой не выполняется автоматически при написании документации.

28. Этапы, трассируемость и сдача

Этап E01: совместимость ARM64, библиотеки, реальные протоколы провайдеров и контрольный корпус. E02: контракты, monorepo, Compose, базовые CI и миграции. E03: identity/ACL и безопасная загрузка. E04: конвейер, preview, OCR, сущности, поиск. E05: интерфейс, версии, обсуждение, корзина. E06: импорт/экспорт обоих облаков. E07: метрики, backup, security, performance, deploy/review и приёмка.

Backlog в tasks.json включает эпики, атомарные задачи, зависимости, требования, критерии и test_steps. Порядок определяется графом зависимостей, не только priority. Размер задачи - один проверяемый результат; обещание «каждая строго 30 минут» не применяется к неизвестным интеграциям. После исследования крупная задача дробится через явную запись change request, не теряя критериев.

Трассируемость. UC-01 → FR-012..015,025..042 → T-004/007/008/009 → NFR-002/005/006. UC-02 → FR-020..024 → T-006. UC-03 → FR-003..006 → T-002/019. UC-04 → FR-051..057 → T-013/014. UC-05 → FR-058..062 → T-015. UC-06 → FR-049..050,070..072 → T-012/022. Полная связь задача-требование хранится машинно в JSON и проверяется валидатором.

Пакет сдачи: README с воспроизводимым запуском, ТЗ Markdown/PDF, архитектурные диаграммы и ADR, OpenAPI, tasks/progress, тестовый отчёт, результаты benchmark и restore, live cloud evidence, PR ссылки, workflow/deploy evidence и демонстрационный сценарий. Секреты и настоящие персональные документы в пакет не входят.

Оставшиеся проверки не являются новыми продуктовыми вопросами: объём RAM/ARM64 расход, совместимость pinned dependencies, OAuth redirect, WebDAV conditional upload и бесплатные аккаунты, reviewer/remote. Они представлены задачами и release gates. Если проверка опровергает baseline, записывается причина, альтернатива и влияние на FR/NFR; нельзя молча снизить требования.

Источники проверены 31.10.2026: Laravel 13 releases/queues/Sanctum; PostgreSQL FTS; OWASP File Upload; FSD pages-first; Tika, Gotenberg, ClamAV; spaCy; Scramble/openapi-typescript; Яндекс REST API; Mail WebDAV; Docker Compose; Render Free. Полные ссылки и ограничения исследования - RESEARCH.md. Ни код приложения, ни успешные интеграционные тесты этим документом не заявляются выполненными.